

El Terreno de Juego del Pentesting

Arquitectura de entornos, riesgos y límites operativos en una auditoría de ciberseguridad.

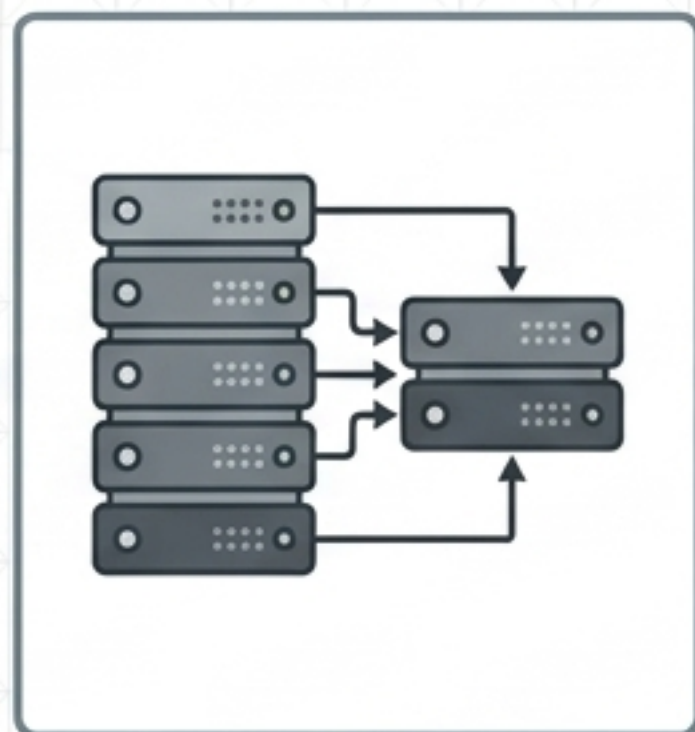
Presentado por Carlos Noboa

El ciclo de vida del código



DESARROLLO

Ordenador del programador o servidor local. Espacio para desarrollar código y realizar pruebas iniciales.



INTEGRACIÓN

Unificación del código desarrollado. Presenta grandes diferencias con los entornos productivos.



PREPRODUCCIÓN

Emula el entorno final. Configuración técnica idéntica a producción, pero con datos anonimizados (sin datos productivos).



PRODUCCIÓN

Ejecución de la aplicación final. Accesos de usuarios reales y manipulación de datos de negocio.

Matriz de contraste operativo



Entornos previos (Desarrollo, Integración, Preproducción)



Menor riesgo operativo al realizar pruebas.



No suelen ser completamente idénticos al entorno final (salvo preproducción).



Los controles de seguridad **perimetral** pueden diferir.



Entornos productivos



Riesgo crítico (potencial caída del servicio o corrupción de datos).



Presencia de usuarios y datos reales.

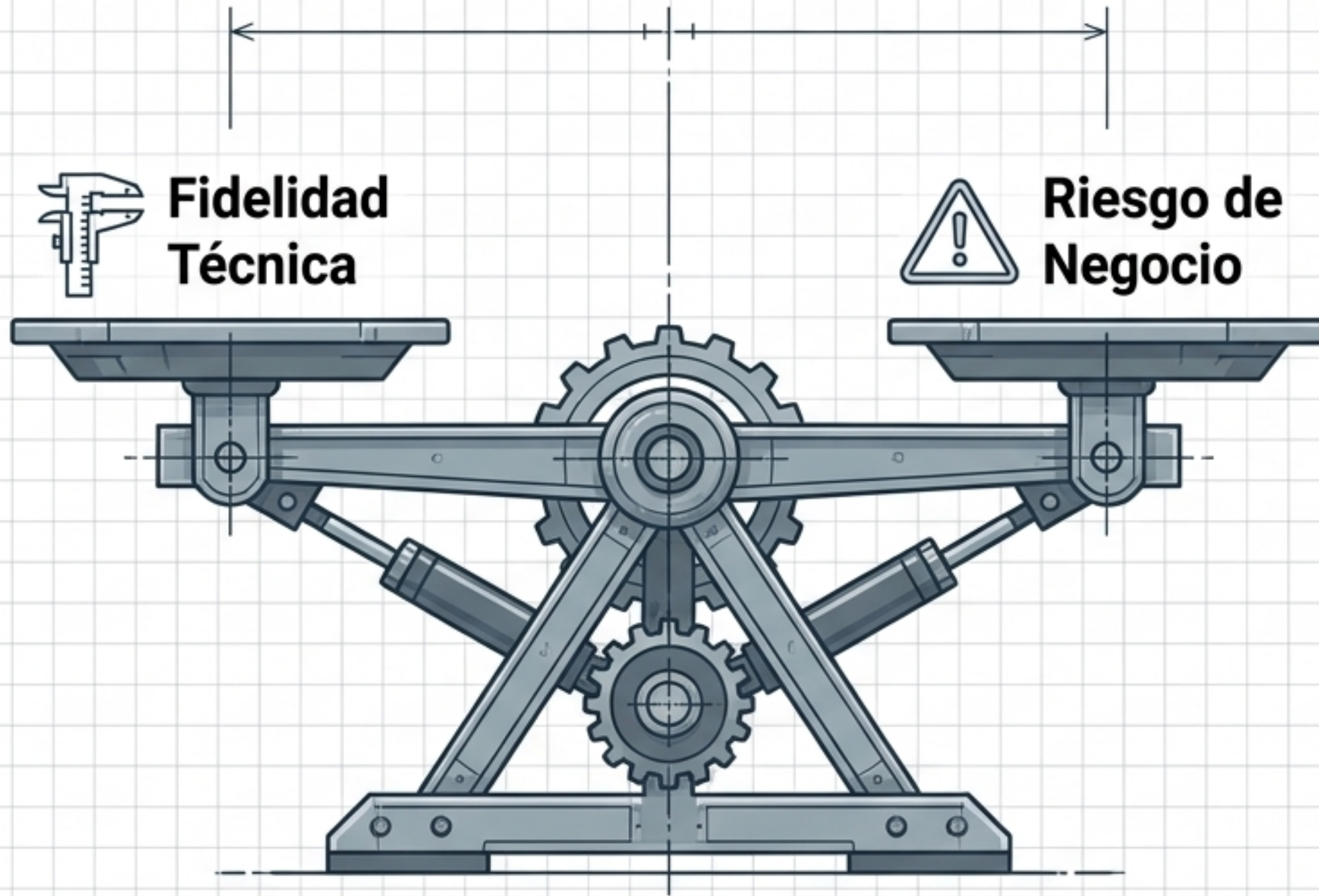


Afectación a funcionalidades con implicaciones fiscales, legales o coste económico.



Controles de seguridad reales y activos (Firewall / WAF).

¿Cuál es el mejor entorno para realizar un pentest?



El Equilibrio Estratégico

La recomendación técnica

El entorno de Preproducción suele ofrecer el equilibrio ideal. Permite auditar una configuración técnica idéntica a la final sin el riesgo de corromper datos de negocio ni provocar denegaciones de servicio a usuarios reales.

La validación final

Sin embargo, pruebas controladas en Producción son necesarias para verificar la eficacia de los controles de seguridad vivos (como WAF y Firewalls) que protegen el entorno real.

Barreras de contención del alcance



Intrusiones físicas

Quedan fuera del alcance las evaluaciones de seguridad a nivel físico (puertas de acceso, cámaras, detectores, lectores NFC).



Ingeniería social

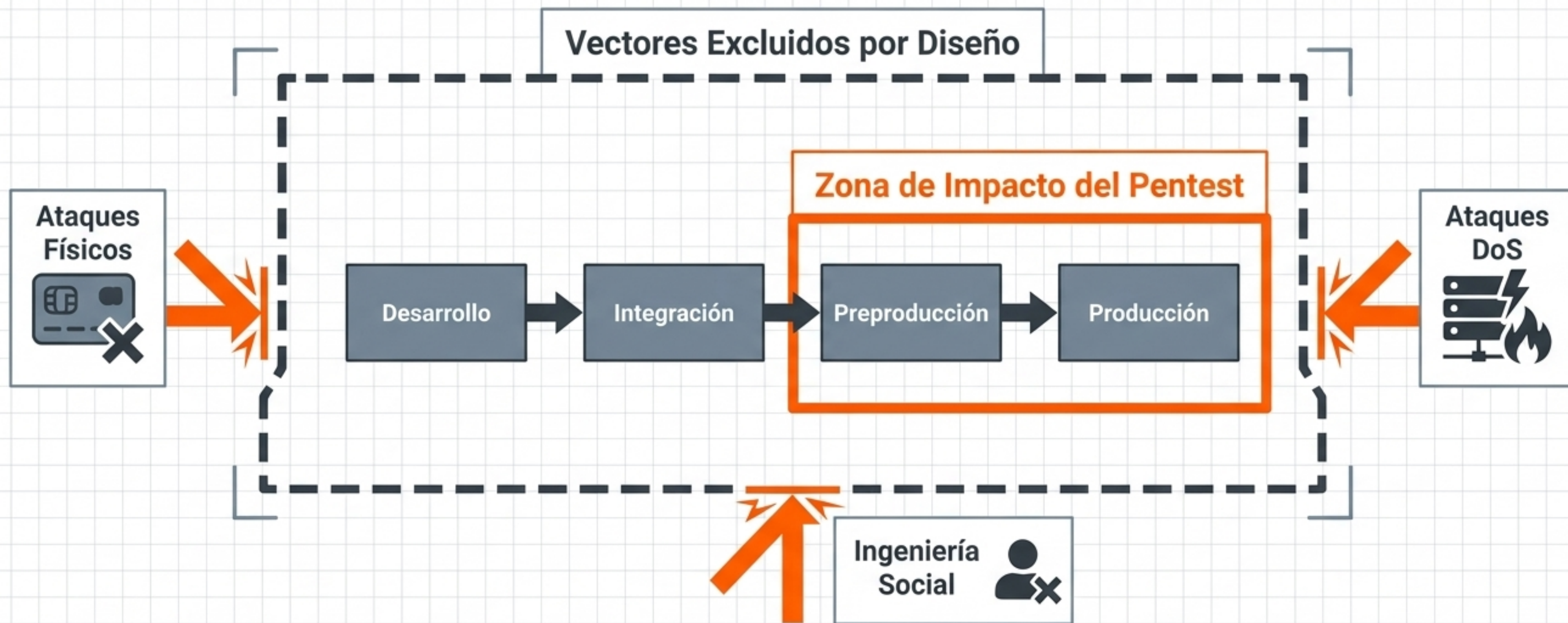
Se excluye la explotación de personas (engaños, phishing directo no autorizado) para conseguir acceso físico o digital a los sistemas de información.



Denegaciones de servicio (DoS)

No se ejecutan ataques dirigidos a agotar los recursos del sistema y atentar contra la disponibilidad de los servicios.

El plano estratégico de la auditoría



Un pentest efectivo maximiza la fidelidad técnica operando en entornos maduros, mientras aísla el riesgo de negocio descartando ataques destructivos o vectores no tecnológicos.